VALIDATE

STORM-0940 SELF-ROLE VALIDATION

Preserve raw Entra role-assignment evidence before detecting service-principal self-escalation.

CLASSIFICATION

Validation query - Untested implementation sketch. Confidence Medium. Behavioral telemetry experiment.

PRIMARY PLATFORM

Microsoft Sentinel. Required telemetry: Entra ID AuditLogs.

OPERATIONAL VALUE 9/10

A privileged service principal assigning itself an administrative role is high-impact. Raw schema validation is required before alert logic.

Executive Assessment

Confirmed behavior, inference and explicit limits

SOURCE FACT

Huntress observed credential additions and privileged role changes on 15 October 2026, including a Teams application identity assigning itself Global Administrator.

SOURCE LIMIT

Huntress could not independently verify Microsoft attribution to ARTEX and lacked Graph request logs. Application-only audit events had no source IP.

DETECTION INFERENCE

Successful Entra role assignments should appear in AuditLogs. Raw InitiatedBy and TargetResources must be inspected before comparing principal identifiers.

UNCONFIRMED

A returned row does not prove self-assignment, Global Administrator, compromise, Storm-0940, ConnectWise involvement, or AI-agent use.

Observed Privilege Path

Only the stages supported by the primary source

1

Trusted access

Compromised ConnectWise application credentials reached downstream Microsoft 365 tenants.

2

Credential planting

Secrets were added, removed and added again; a certificate upload initially failed.

3

Role escalation

An application identity assigned itself Global Administrator and roles were also granted to sibling principals.

4

Rapid adaptation

Tooling changed between runs; this is analyst context, not a stable detection signal.

5

Visibility gap

Graph reads were not logged by affected tenants, limiting reconstruction.

BOUNDARY

The published query validates role-assignment logging only. It does not correlate identity objects yet.

Telemetry & Evidence Model

Documented AuditLogs fields, raw dynamics preserved

AuditLogs	**Required**	Microsoft Entra audit stream
OperationName	**Required**	Documented activity name
Result	**Required**	success/failure state
InitiatedBy	**Required**	Raw initiating user or app
TargetResources	**Required**	Raw changed resources
Identity	**Enrichment**	Token identity summary
Id / CorrelationId	**Required**	Event and workflow context

UNAVAILABLE

Source IP for application-only audit events and unenabled Microsoft Graph activity logs cannot be recovered from these rows.

Primary Validation Query

Microsoft Sentinel - raw role assignment collection

```
AuditLogs
| where OperationName in ("Add member to role",
    "Add eligible member to role")
| where Result =~ "success"
| project TimeGenerated, Id, CorrelationId, OperationName,
          Category, LoggedByService, Identity, InitiatedBy,
          TargetResources, Result, ResultDescription
| order by TimeGenerated desc
```

CONDITION EVIDENCE

Both operation names are documented RoleManagement activities. Result values and projected columns are documented in AuditLogs. No nested mapping or threshold is assumed.

STATUS

Validation query - Untested implementation sketch. Keep non-alerting until representative events establish actor, principal and role semantics.

Cross-SIEM Assessment

No mechanical translations

SPLUNK

No reliable implementation can currently be written. Required: raw Entra directory audit event, index, sourcetype, parser, and extracted initiator/target/role identifiers.

CHRONICLE YARA-L 2.0

No reliable implementation can currently be written. Required: Entra parser name, UDM event type, principal/target mapping and a representative role-assignment event.

DEFENDER XDR

CloudAppEvents may expose related activity depending on licensing and product coverage, but the source does not verify an equivalent schema. Microsoft Sentinel AuditLogs is the direct documented source.

EVIDENCE TO COLLECT

One benign service-principal role assignment, one user-initiated assignment, one PIM assignment, and one controlled app-to-self assignment if authorized.

Validation Plan

Promotion depends on exact identifier semantics

01 Run the query across retention and export representative raw events without flattening dynamic fields.

02 Identify the exact InitiatedBy app service-principal identifier and the target principal identifier.

03 Locate the role display name or template identifier for Global Administrator and Privileged Role Administrator.

04 Test whether app-to-self equality is stable across direct, PIM and administrative assignment paths.

05 Reject production promotion if actor, target or role mapping is missing, ambiguous or license-hidden.

SUCCESS CRITERION

A controlled self-assignment produces stable identifiers that can be compared without coalescing unrelated semantics; benign workflows are characterized.

ATT&CK, Conclusion & References

Evidence-backed scope and publication record

MITRE ATT&CK T1098.003

Additional Cloud Roles is directly supported by the observed application identity granting itself Global Administrator privileges.

CONCLUSION

The behavior is high-value, but a raw validation query is the defensible first step. Self-assignment logic must wait for local schema evidence.

PRIMARY RESEARCH

Huntress. AI, Scripts, Operator: Inside the ConnectWise Attack. 26 October 2026.

hxxps://www[.]huntress[.]com/blog/connectwise-attack-ai

OFFICIAL SCHEMA

Microsoft Learn. AuditLogs table and Entra audit activity reference.

hxxps://learn[.]microsoft[.]com/en-us/azure/azure-monitor/reference/tables/auditlogs

QUALITY CONTROLS

Eight pages; raw dynamic fields preserved; no arbitrary threshold; no customer data; links defanged; no cross-SIEM pseudorules.